

Underlag inför möte — CVmatchen

Till: Isabella Seiger, Innovationsledare, Arbetsmarknadsförvaltningen Helsingborg

Från: Oliver Pettersson — SYV, grundare PathfinderAI

Datum: 2026-07-07

Detta dokument samlar det tekniska och juridiska underlaget för CVmatchen inför fördjupad genomgång. Det innehåller fyra delar: **1. Teknisk specifikation**, **2. Personuppgiftsbiträdesavtal (utkast)**, **3. Konsekvensbedömning/DPIA (utkast)**, **4. Kunskapskällor** bakom träningsmodulerna.

Utkasten till PUB och DPIA är förberedda av leverantören som underlag — de ägs och slutförs av kommunen (dataskyddsombud och jurist) innan skarp drift.

Innehåll

- 1. Teknisk specifikation** — arkitektur, säkerhet, GDPR, drift
- 2. PUB-avtal (utkast)** — personuppgiftsbiträdesavtal enligt art. 28
- 3. DPIA (utkast)** — konsekvensbedömning enligt art. 35
- 4. Kunskapskällor** — evidens bakom träningsinnehållet

DEL 1 — TEKNISK SPECIFIKATION

Översikt

CVmatchen är en webbaserad SaaS-tjänst (Progressive Web App) som hjälper arbetssökande att skapa CV, matcha mot lediga tjänster och få handledning från arbetsmarknadshandläggare. Hela teknikstacken ligger inom EU/EES för GDPR-efterlevnad.

Arkitektur — var data ligger

```
KLIENT (webbläsare / hemskrms-PWA)
  | HTTPS (TLS 1.3)
  v
APPLIKATIONSLAGER — Vercel Edge (Stockholm, arn1)
  • Statiska sidor + serverless functions (/api)
  |
  v
DATABAS              AI-INFERENS
Supabase Postgres    AWS Bedrock
Frankfurt (EU)       Frankfurt (eu-central-1, EU)
Row-Level Security   eu.anthropic.claude-* (EU-only)
  ^
  |
AUTH: OTP (invånare) · Microsoft OAuth (handläggare)
  |
  v
MEJL: Resend (EU) — inbjudningar, engångskoder
```

Lager	Leverantör	Region
Statiska sidor + logik	Vercel	Stockholm (arn1)
Databas (all persondata)	Supabase Postgres 17	Frankfurt (eu-central-1)
AI-inferens	AWS Bedrock (Claude)	Frankfurt (eu-central-1)
Transaktionsmejl	Resend	EU
Felövervakning	Sentry	EU
Inloggning personal	Microsoft EntraID	EU

Ingen data lämnar EU/EES. Ingen tredjelandsoverföring → ingen SCC/TIA-process krävs.

Klient (frontend)

- **Vanilla JavaScript** — inga ramverk. Snabb laddning, liten angreppsytta, lång livslängd.
- **Systemfonter** — inga Google Fonts, ingen extern spårning.
- **PWA** — installeras på hemskärm utan App Store; offline-fallback via localStorage, synkar mot databasen.
- **XSS-skydd** — all användardata escapad; DOM-XSS-revision genomförd juni 2026.

Applikationslager (Vercel Serverless, Stockholm)

- `/api/supabase.js` — CRUD + auth. Alla admin-anrop går genom `requireAdmin()` som HMAC-verifierar handläggarens sessionstoken, slår upp färskas behörigheter och kontrollerar att begärd kommun/enhet/deltagare ligger inom handläggarens tenant.
- `/api/chat.js` — AI-proxy mot AWS Bedrock (EU). Inga prompts lagras permanent.
- `/api/pdf.js` — PDF-generering (wkhtmltopdf + pandoc).
- `/api/v1/auth/microsoft/*` — OAuth-flöde med CSRF-skydd och invite-token för handläggare.

Databas (Supabase / PostgreSQL 17, Frankfurt)

- **Row-Level Security (RLS)** på alla tabeller med personuppgifter. Deltagare ser bara sin egen data; handläggare bara deltagare inom sin kommun/enhet.
- **Service-nycklar** används enbart serverside efter verifierad admin-behörighet — aldrig i klienten.
- **Backup**: dagliga säkerhetskopior, 7 dagars retention, point-in-time recovery.

AI-lager (AWS Bedrock, Frankfurt)

- Claude-modeller via Bedrock med modell-ID:n `eu.anthropic.*` — cross-region inference som håller all inferens inom EU.
- CV-data **lagras inte** hos AI-leverantören och **används inte för modellträning**.
- Intervjuträning: claude-sonnet-4-6 · CV-AI/matchning: claude-haiku-4-5 / sonnet-4-6.
- **Bedrock-EU aktivt i drift sedan 2026-06-18.**

Autentisering

- **Invånare**: e-post + engångskod (OTP, 6 siffror, 5 min giltighet) via Supabase Auth.
- **Handläggare**: Microsoft EntraID OAuth + invite-token vid första inloggning. HMAC-signerad sessionstoken (24h).
- **Inbjudningar**: handläggare skapar invite → mejl via Resend → deltagaren loggar in med OTP → kommun/enhet kopplas på automatiskt.

Säkerhetsåtgärder i drift

- TLS 1.3 (HSTS preload), CSP, X-Frame-Options, X-Content-Type-Options.
- HMAC-SHA256 för sessionstokens (constant-time-jämförelse).
- Multi-tenant-isolation med deny-by-default; avvisade åtkomstförsök loggas.
- Rate-limiting på AI-anrop, PII-maskering i loggar, Sentry-felövervakning, egna 404/500-sidor.

Drift, skalbarhet och vidareutveckling

- **Deploy:** automatisk från `main`-branch till cvmatchen.com. Instant rollback via Vercel.
- **Skalbarhet:** nuvarande arkitektur klarar 5 000+ simultana användare utan kodändring. För Helsingborgs pilot (~10 deltagare) finns 100× marginal.
- **Färdplan:** WCAG-granskning (extern), App Store/Google Play via Capacitor, penetrationstest, källredovisning per modul.

DEL 2 — PUB-AVTAL (UTKAST)

Personuppgiftsbiträdesavtal

Mellan **Helsingborgs stad, Arbetsmarknadsförvaltningen** (Personuppgiftsansvarig) och **PathfinderAI** (Personuppgiftsbiträde), genom tjänsten CVmatchen.

Företagsform: PathfinderAI drivs i dag som enskild firma. Registrering av aktiebolag planeras inför ett skarpt avtal — bland annat för att stärka ansvars- och kontinuitetsfrågan gentemot kommunen. Avtalspart justeras till aktiebolaget om/när det är registrerat.

Utkastet följer strukturen i SKR:s mallavtal och GDPR art. 28. Använd kommunens egen mall om sådan finns — texten nedan är förslag på innehåll, anpassad för CVmatchens behandling. Bör granskas av kommunens dataskyddsombud och jurist innan undertecknande.

Kärnbestämmelser

- **Instruktioner:** biträdet behandlar personuppgifter enbart enligt PUA:s dokumenterade instruktioner och detta avtal.
- **Säkerhet:** biträdet vidtar lämpliga tekniska och organisatoriska åtgärder (Bilaga B).
- **Underbiträden:** generellt förhandsgodkännande med 30 dagars underrättelse vid förändring; PUA har invändningsrätt (Bilaga C).
- **Tredjelandsoverföring:** ingen överföring utanför EU/EES sker; kräver annars PUA:s uttryckliga skriftliga samtycke.
- **Tystnadsplikt** för all personal som behandlar uppgifterna.
- **Bistånd:** biträdet hjälper PUA att uppfylla registrerades rättigheter samt skyldigheter enligt art. 32–36.
- **Incident:** anmälan till PUA utan onödigt dröjsmål, senast inom **24 timmar** från upptäckt.
- **Granskning:** PUA har revisionsrätt (dokumentation, på plats-revision, tredjepartsrapport).
- **Avslut:** radering eller återlämning av all data i öppet format, med skriftlig bekräftelse.

BILAGA A — BEHANDLINGEN

Ändamål: CV-skapande, jobbmatchning, intervjuträning och uppföljning inom kommunal arbetsmarknadsverksamhet. Varaktighet: pilot 3 månader, därefter förlängning vid direktupphandling.

Kategorier av uppgifter: identitet (namn), kontakt (e-post, telefon), CV-innehåll (erfarenhet, utbildning,

kompetenser, körkort, certifikat), aktivitetsdata, AI-konversationer (pseudonymiserade). **Inga särskilda kategorier** (art. 9) behandlas avsiktligt; fritext varnas mot att innehålla sådant.

BILAGA B — SÄKERHETSÅTGÄRDER

Tekniska: TLS 1.3, OTP + OAuth + HMAC-tokens, Row-Level Security, kryptering at rest (AES-256), dagliga automatiska säkerhetskopior (7 dagars retention; point-in-time recovery kan aktiveras inför skarp drift), Sentry-övervakning, audit-logg. **Organisatoriska:** privat repo med branch-protection, inga produktionsdata i utveckling, tystnadsplikt, incidentrutin med 24h-frist.

BILAGA C — UNDERBITRÄDEN

Underbiträde	Tjänst	Behandlingsregion
Vercel	Hosting + serverless	Stockholm (EU)
Supabase	Databas + auth	Frankfurt (EU)
AWS Bedrock	AI-inferens	Frankfurt (EU)
Resend	Transaktionsmejl	EU
Sentry	Felövervakning (ej PII)	EU
Microsoft	Inloggning personal	EU

Samtliga behandlar data inom EU/EES. Respektive leverantörs DPA finns och kan tillhandahållas på begäran.

DEL 3 — DPIA (UTKAST)

Konsekvensbedömning avseende dataskydd

En DPIA ska ägas och slutföras av kommunen (dataskyddsombudet). Detta är ett leverantörsförberett underlag. Behandlingen får inte tas i drift med skarpa personuppgifter förrän DPIA:n är slutförd och godkänd.

Behövs en DPIA? — Ja

Behandlingen träffar flera riskkriterier: profilering (AI-matchning), **sårbar målgrupp** (arbetssökande i beroendeförhållande), **potentiellt känsliga uppgifter** i fritext (art. 9), och **innovativ teknik** (generativ AI). DPIA krävs.

Automatiserat beslutsfattande (art. 22) — nej

AI:n föreslår — människan beslutar. Ingen myndighetsbedömning fattas av AI:n.

Matchningar, profiltexter och intervjufeedback är förslag som deltagaren och handläggaren godkänner. Aktivitetsloggen är ett underlag bland flera i handläggarens helhetsbedömning — en miss i systemet kan aldrig ensam leda till indraget eller minskat försörjningsstöd.

Riskanalys (urval)

Risk	Nivå	Skydd	Restrisk
Obehörig åtkomst	Medel	RLS, tenant-isolation, TLS, kryptering	Låg-Medel
Cross-tenant-läcka	Medel	Serverside verifyAdmin, deny-by-default	Låg
Känsliga uppgifter i fritext (R3)	Hög	AI-samtycke + varningstext (åtgärdad) + människa-i-loopen	Medel
AI-text felaktig	Medel	Deltagaren granskar/godkänner allt	Låg
AI-data lämnar EU	Låg-Medel	Bedrock EU, ingen lagring/träning	Låg
Aktivitetslogg → försörjningsstöd	Medel	Loggen är underlag, ej beslut	Låg-Medel
Leverantörsberoende	Medel	Escrow, dataportabilitet, SLA	Låg-Medel

Åtgärder innan skarp drift

Åtgärd	Ansvarig	Status
Varningstext vid CV-fritextfält	PathfinderAI	✓ Klar
AI-samtyckesflöde i drift	PathfinderAI	✓ Klar
Bedrock-EU aktivt	PathfinderAI	✓ Klar
Handläggarrutin: logg = underlag, ej beslut	Kommunen	⌛
PUB-avtal undertecknat	Båda	⌛
Fastställ laglig grund för art. 9-data	Dataskyddsombud	⌛
Fastställ lagringstid	Dataskyddsombud	⌛
Extern WCAG-granskning	PathfinderAI	⌛ (tidigt i pilot)
DPIA slutförd och godkänd	Dataskyddsombud	⌛

DEL 4 — KUNSKAPSKÄLLOR

Evidens bakom träningsmodulerna

Innehållet bygger på etablerade myndighets- och forskningskällor, men är ännu inte formellt peer-reviewat eller utvärderat i kontrollerad studie. Vi föreslår en gemensam effektutvärdering under pilotperioden.

Kategori	Primära källor
Arbete — CV, jobsökning, intervju	Arbetsförmedlingen (yrkesguider, lönestatistik), Saco, Unionen, OECD Skills Outlook. Intervju: STAR-metoden (beteendintervjuforskning, HBR).
Studier	Skolverket, UHR, CSN, Studieinfo.se, Yrkehögskolan.se, Folkbildningsrådet.
Hälsa	Folkhälsomyndigheten, 1177 Vårdguiden, WHO, FYSS (Socialstyrelsen), NASP (suicidprevention).
Ekonomi	Konsumentverket / Hallå Konsument, Skatteverket, Finansinspektionen (Gilla Din Ekonomi), Pensionsmyndigheten, Kronofogden.
Digitalt	EU DigComp 2.2, Internetstiftelsen, MSB, DIGG.
Intervjuträning (AI)	STAR-metoden + Behavioral Event Interview (kompetensbaserad rekrytering); branschfrågor från Arbetsförmedlingens yrkesguider.

Kvalitetssäkring

- Lag- och regelförändringar (skatt, studiemedel) går igenom kvartalsvis mot källmyndigheternas senaste utgåvor.
- CVmatchen ger inte juridisk, medicinsk eller finansiell rådgivning — modulerna hänvisar vidare till relevanta myndigheter (1177, Konsumentverket m.fl.).
- AI-genererade förslag är förslag — deltagaren fattar alltid det slutgiltiga beslutet.

Föreslagen effektutvärdering under piloten

- Andel deltagare som slutfört minst en modul efter 4 veckor.
- Upplevd förbättring i beredskap för arbetsmarknaden (pre/post-enkät).
- Antal genomförda intervjuövningar per deltagare.

Resultatet kan ligga till grund för Visionsfondens-ansökan hösten 2026 och eventuell forskningssamverkan med Lunds eller Malmö universitet.